



2025年网络安全状况 特点及2026年趋势研判

千里目安全技术中心



前言	01
----	----

 安全漏洞趋势分析	02
--	----

• 安全漏洞威胁趋势分析	03
--------------	----

• 漏洞利用情况分析	04
------------	----

已知被利用漏洞分析	04
-----------	----

0day漏洞利用态势分析	06
--------------	----

关键漏洞盘点	07
--------	----

• 安全漏洞小结	10
----------	----

 恶意软件攻击发展趋势分析	11
--	----

• 恶意软件攻击趋势分析	12
--------------	----

• 恶意软件网络犯罪团伙分析	14
----------------	----

• 恶意软件小结	17
----------	----

 攻防场景发展趋势分析	18
--	----

• 攻防场景下初始访问阶段技战法分析	19
--------------------	----

• 攻防场景下横向移动阶段技战法分析	20
--------------------	----

• 攻防场景下大模型攻防技战法分析	21
-------------------	----

ENTS

应用安全技战法分析	21
内容安全技战法分析	22
• 攻防场景小结	24
 人工智能安全趋势分析	27
• 人工智能安全风险治理分析	28
人工智能安全风险趋势分析	28
人工智能安全风险治理体系分析	29
• AI赋能网络安全趋势分析	31
• 大模型系统自身安全趋势分析	32
大模型系统防护对象分析	32
AI系统防护策略变化分析	32
AI自身安全防护产业情况分析	33
• 人工智能安全小结	34
 2026年重点关注趋势	35
 参考链接	37



前言

当前，数字化浪潮与智能化变革深度交融，网络空间已成为大国博弈与社会运转的关键基础。2025 年，全球网络安全形势延续高压态势，威胁烈度与攻击复杂度双双升级，防御体系面临前所未有的挑战。

漏洞层面，2025 年国家信息安全漏洞库收录漏洞同比增长 20.77%，约 30% 的漏洞在披露后 24 小时内即遭武器化利用，0day 与 Nday 边界持续弱化，防御窗口急剧收窄。恶意软件攻击呈现出 " 远控化、工具化、服务化 " 的产业特征，勒索软件团伙攻击事件数量较 2024 年增长约 43%，网络犯罪产业生态日趋成熟。在攻防对抗层面，身份系统漏洞利用、供应链攻击与大模型安全问题三线并发，攻击者正借助人工智能技术实现攻击流程的高度自动化与智能化。

2025 年人工智能安全已从 " 理论风险 " 全面转向生产环境的真实破坏。提示注入、Agent 过度权限、信任链滥用等新型攻击手法频繁出现，EchoLeak、Langflow 等 AI 漏洞被纳入 CISA 已知被利用漏洞目录，AI 基础设施与智能体生态正成为攻击者重点突破的高价值目标。面对这一局面，各国加快推进 AI 安全治理体系建设，治理重心加速从 " 事后修复 " 向 " 全生命周期前置防控 " 转变。

展望 2026 年，身份验证系统与 API 接口将成为漏洞利用的重点目标，恶意软件将向高欺骗性伪装与产业化方向持续演进，AI 赋能的攻防 " 军备竞赛 " 将进入自动化新阶段，AI 赋能的攻防 " 军备竞赛 " 进入自动化新阶段，大模型安全与智能体身份治理将成为核心议题。攻击周期的急剧压缩，使防御速度成为决胜关键。

本报告由深信服千里目安全技术中心基于全年网络安全数据观测及行业实战经验编制而成，系统梳理了 2025 年安全漏洞、恶意软件、攻防场景与人工智能安全的发展态势，并对 2026 年五大重点趋势作出研判。希望本报告能够为用户、安全从业者及相关机构提供有价值的参考，助力各方在智能化时代的网络安全实践中筑牢防线。

声明

本报告除明确注明来源以外，数据均来自深信服千里目安全技术中心，目的仅为帮助客户及时了解中国或其他地区网络安全的最新动态和发展，仅供参考。

本报告中所含内容乃一般性信息，不应被视为任何意义上的决策意见或依据，任何深信服科技股份有限公司的关联机构、附属机构（统称为“深信服股份”）并不因此构成提供任何专业建议或服务。在作出任何可能影响您的财务或业务的决策或采取任何相关行动前，或您对本报告内容有任何问题与建议，可联系深信服官方。



PART ONE

安全漏洞趋势分析





安全漏洞威胁趋势分析

2015 年至 2025 年，我国国家信息安全漏洞库（CNNVD）和美国国家漏洞库（NVD）近十年漏洞收录情况如图 1-1 所示，国内外漏洞库收录漏洞数量的变化趋势保持一致。



图 1-1 近十年漏洞披露数量（来源：CNNVD 漏洞库和 NVD 漏洞库）

近三年来漏洞发现和披露速度逐年递增，自 2023 年开始漏洞披露数量快速增加。2025 年国家信息安全漏洞库（CNNVD）共收录漏洞信息 48360 条，同比 2024 年漏洞收录数量增加 20.77%。





漏洞利用情况分析

已知被利用漏洞分析

近年来，已知漏洞被持续利用并引发的网络安全事件频繁发生。为降低已知漏洞长期未修复带来的安全风险，美国于 2021 年将已知漏洞利用列为国家网络安全重大风险，发布《约束性操作指令》(BOD22-01)，并建立“已知被利用的漏洞目录”(KEV 目录)，要求联邦民事行政部门在规定期限内修复目录中的漏洞。随着实践推进，KEV 目录逐步成为国际上识别已知在野利用漏洞的重要参考，为各类组织制定漏洞修复优先级提供了权威依据。

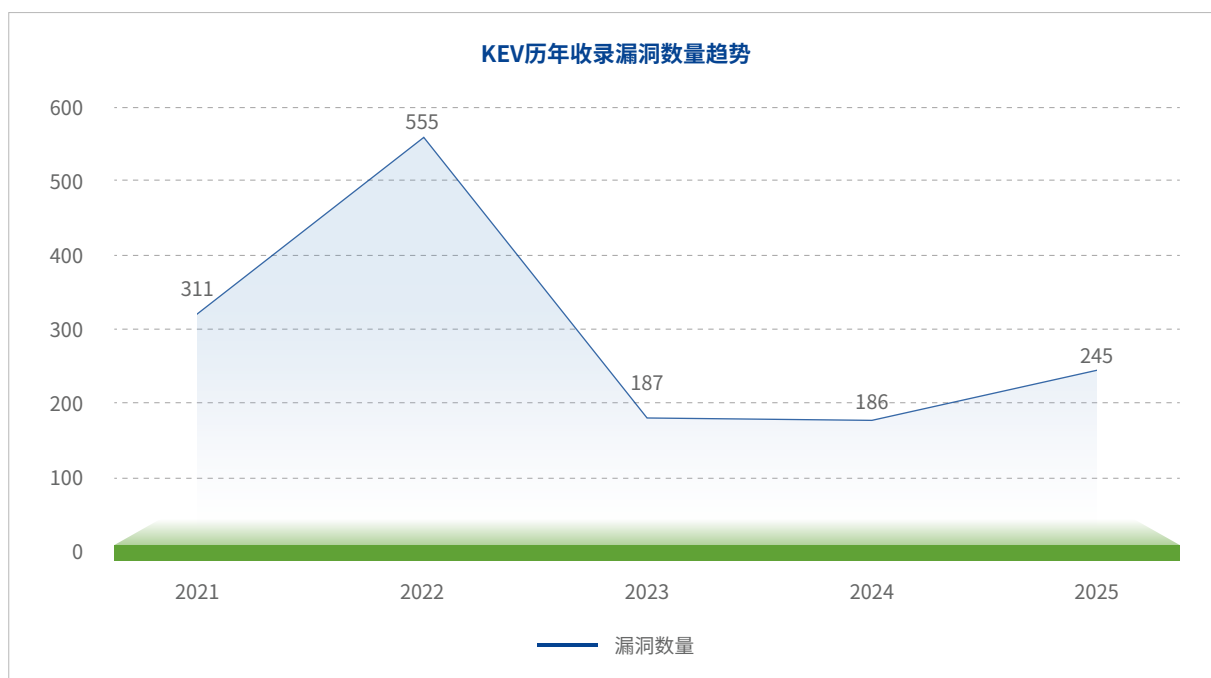


图 1-2 KEV 目录近十年漏洞利用情况（来源：KEV 目录）

2021 年和 2022 年，KEV 机制处于建立和完善阶段，对历史上已确认存在在野利用的漏洞进行了集中梳理和回溯性收录，该阶段收录数量显著偏高。自 2023 年起，KEV 目录逐步进入常态化运行阶段，收录以当年新发现且已确认被在野利用的漏洞为主，年度收录数量随之回落并趋于稳定。2023 年和 2024 年分别收录 187 和 186 个漏洞，漏洞利用情况维持在相对稳定的水平。2025 年 KEV 收录数量上升至 245 个，在常态化运行机制下出现阶段性增长，漏洞利用活跃度提升，其中被利用漏洞主要体现在企业应用、网络边界设备及关键基础设施上。典型案例包括 React2Shell 漏洞，影响 React、Next.js 等主流 Web 框架，攻击者借此部署 Mesh Agent 后门、加密货币挖矿及 Web 壳，并引发全球范围的大规模 Web 应用扫描，随后被 CISA 快速纳入 KEV 目录；Microsoft SharePoint 的 ToolShell 利用链被用于大规模勒索软件初始访问，在数据窃取后实施加密，因 Microsoft SharePoint 在企业及政府机构中的广泛部署而影响面较大；此外，Citrix NetScaler 内存泄露漏洞被 RansomHub 等多个勒索团伙规模化利用，攻击者通过窃取会话 Cookie 实现横向移动并最终部署勒索软件，成为 2025 年 VPN 及网关类设备漏洞被集中利用的代表性事件。

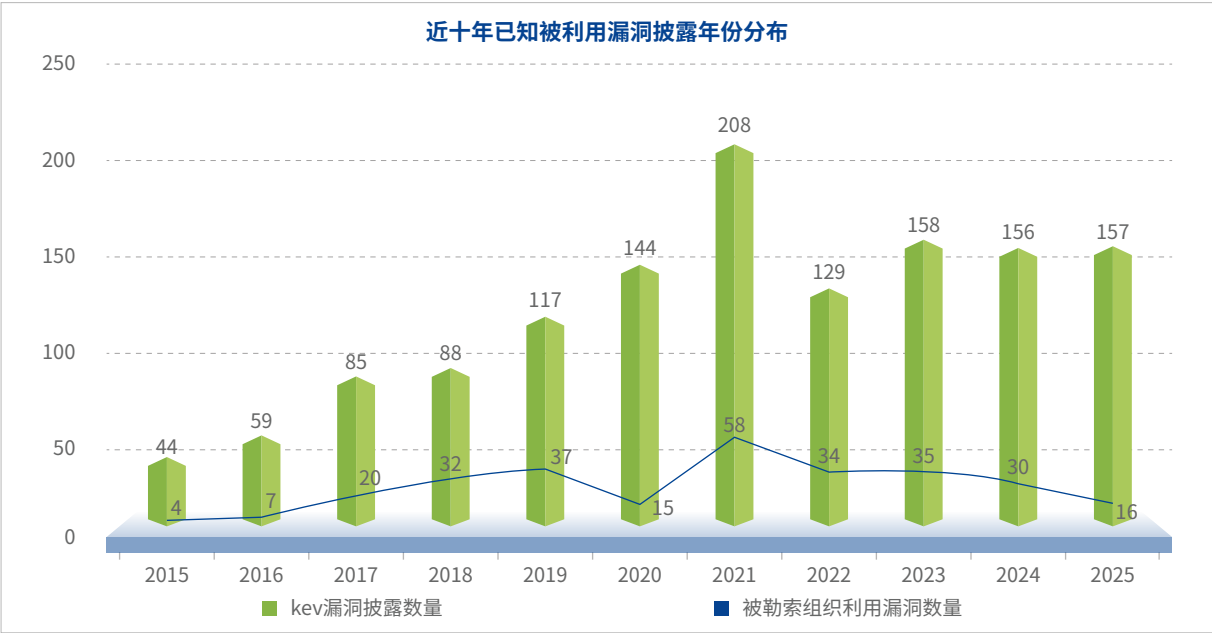


图 1-3 KEV 目录近十年漏洞利用情况（来源：KEV 目录）

近三年，已知被利用漏洞数量整体呈现出高位稳定、伴随小幅波动的特征。勒索等高组织化攻击主体反复利用的漏洞数量在 2025 年的漏洞中出现下降趋势，攻击组织在已知漏洞中存在明显的筛选机制，更倾向于集中利用少量适配性强、可稳定复用的漏洞，而非全面覆盖所有可利用漏洞。

2025 年 30% 的漏洞在公布后 24 小时内被武器化，漏洞利用时间窗口进一步缩短，0day 与 Nday 的界限正在减弱，根据 deepstrikes 分析数据，表明新披露漏洞在较短时间内被利用并进入攻击链的情况已成为常态。尤其是 React2Shell 漏洞 (CVE-2025-55182) 几乎立即被武器化，其公开披露后的几个小时内就出现了大规模利用尝试，使其成为 2025 年被利用速度最快的 CVE 之一。

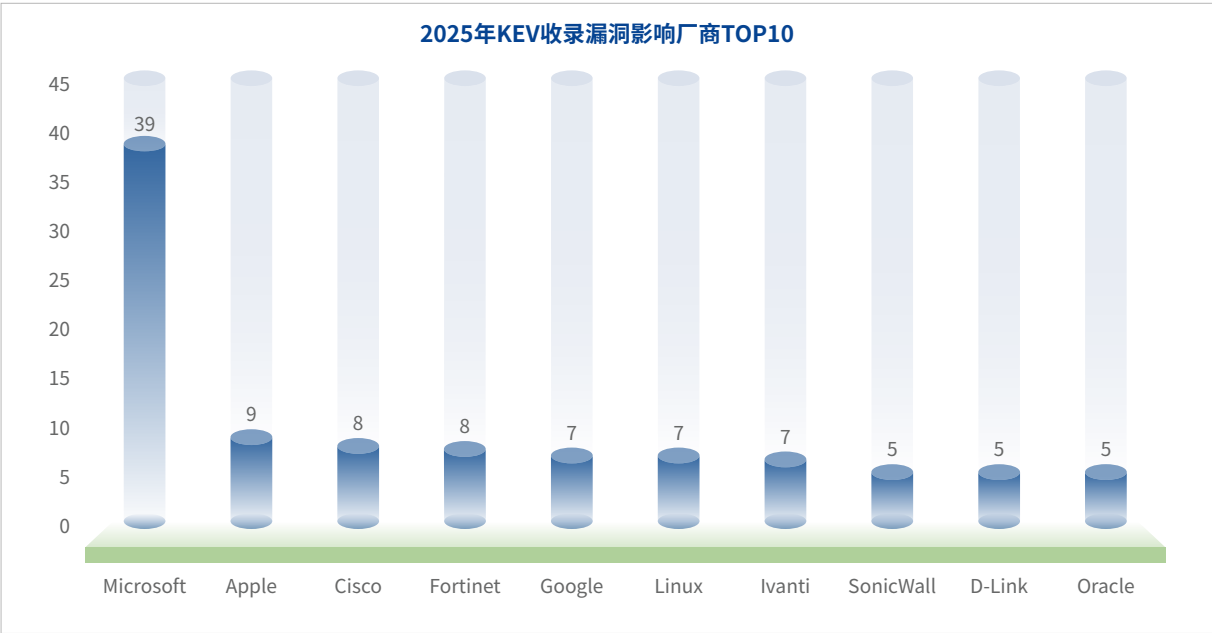


图 1-4 2025 年 KEV 收录漏洞影响厂商 TOP10（来源：KEV 目录）

Microsoft、Apple、Linux 相关漏洞数量靠前，反映出**操作系统及基础运行环境仍是攻击者重点关注的目标**。这类产品部署广泛、权限级别高，一旦被利用，往往可作为攻击链的核心入口或控制点。

边界设备和安全基础设施仍是已知漏洞利用的重要攻击面。Cisco、Fortinet、SonicWall、D-Link 等网络及安全设备厂商均进入 TOP10，这类漏洞一旦被利用，往往直接影响组织整体安全边界。

 0day 漏洞利用态势分析

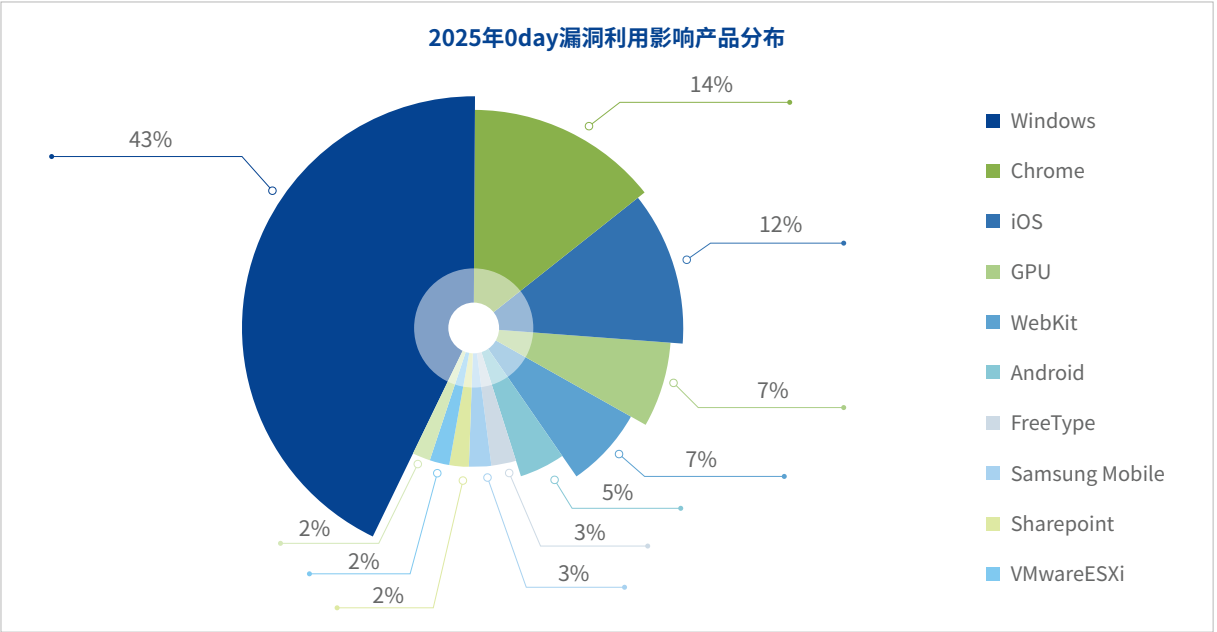


图 1-5 2025 年 0day 漏洞利用影响产品分布（来源：GoogleProjectZero）

移动端利用频率虽不如 2024 年高峰期，但攻击复杂度更高，常链式组合实现零点击链，典型为苹果 iOS 的零点击漏洞，该漏洞利用方式被多次使用，导致近年屡次发生重大网络安全事件。苹果在 2025 年全年紧急发布了多次补丁，修复了至少 7-9 个在野利用的零日漏洞，其中多个明确为零点击类型，该类漏洞主要用于情报窃取攻击，允许攻击者在无需用户任何交互（如点击链接、打开附件）的情况下，通过恶意图像、iCloud 链接、Web 内容或消息触发远程代码执行（RCE），导致设备接管、数据窃取或持久驻留，如著名的三角行动攻击活动。

操作系统与基础平台仍是 0day 利用核心目标，攻击重心高度集中在 Windows 等高部署规模平台。操作系统在 0day 漏洞利用中，一直是占比最高的影响对象。如图 1-5 所示，2025 年 0day 漏洞利用所影响产品中，Windows、iOS、Android 等操作系统类产品共计占比高达 59.52%，与 2024 年数据变化较明显一点为，2024 年移动端 0day 占比高，而 2025 年则是 Windows 系统漏洞占据断层第一，攻击者利用重心发生明显转变，高度集中在 Windows 等高部署规模平台。

浏览器及内核类产品位居第二梯队，Chrome 与 WebKit 在整体占比中处于第二梯队，浏览器仍是 0day 利用的重要攻击面。浏览器及其内核天然处于高暴露环境，常被用于钓鱼、网页投递和跨平台攻击，是 0day 初始访问阶段的重要载体。

GPU、FreeType、VMwareESXi 等底层组件和基础设施类产品虽占比较低，但其出现具有显著意义。这类漏洞往往具备跨版本、跨产品复用性强的特点，一旦被掌握，可在不同攻击场景中反复利用，体现出攻击者在 0day 选择上的技术深度。

关键漏洞盘点

2025 年漏洞利用攻击活动呈现出攻击面前移、利用链专业化和设备类漏洞占比上升的趋势，本表所列漏洞均在披露前已被确认存在真实利用行为，涵盖服务器软件、网络边界设备、操作系统与应用框架等多个层面。其中网络设备与基础设施类漏洞占比较多，和 2024 年攻击趋势相同，攻击者会优先选取此类互联网边界或企业关键业务入口进行规模化入侵，再结合 CitrixBleed2 会话泄露漏洞横向移动，通过操作系统漏洞提权完成漏洞组合链利用。

指令	漏洞类型	危害级别	功能简述	功能简述
MicrosoftSharePoint 反序列化远程代码执行漏洞 (CVE-2025-53770)	反序列化 RCE	严重	APT 攻击 / 勒索软件初始入侵	2025-03
CitrixNetScaler 内存泄露漏洞 (CitrixBleed2, CVE-2025-5777)	内存泄露 / 会话劫持	高危	APT 攻击 / 勒索软件横向移动	2025-02
LinuxSudo 本地特权提升漏 洞 (CVE-2025-32463)	本地权限提升	高危	APT 攻击 / 勒索软件提权阶段	2025-01
CiscoASA/FTD 缓冲区溢出 远程代码执行漏洞 (CVE-2025-20333)	缓冲区溢出 RCE	严重	APT 攻击 / 网络边界突破	2025-04
OracleBIPublisher 未授权远 程代码执行漏洞 (CVE-2025-61882)	未授权 RCE	严重	APT 攻击 / 企业应用入侵	2025-02
ReactServerComponents 远 程代码执行漏洞 (Re- act2Shell, CVE-2025-55182)	服务端模板注入 /RCE	严重	供应链攻击 /Web 服务入侵	2025-05
Fortinet 网络安全设备堆溢 出远程代码执行漏洞 (CVE-2025-32756)	堆溢出 RCE	严重	APT 攻击 / 勒索软件边界入侵	2025-03
MicrosoftWSUS 反序列化远 程代码执行漏洞 (CVE-2025-59287)	反序列化 RCE	严重	APT 攻击 / 供应链攻击	2025-04
Android 内核本地特权提升 漏洞 (CVE-2025-48633)	内核提权	严重	APT 攻击 / 定向监控	2025-01
AppleWebKit 沙箱逃逸漏洞 (CVE-2025-14174)	内存破坏 / 沙箱逃逸	严重	APT 攻击 / 定向监控	2025-02

表 1-1 2025 年关键 0day 漏洞利用盘点

除以上通用场景下的高频漏洞利用之外，2025 年，AI 漏洞已从“理论风险”转向真实生产破坏，尤其是提示注入和 Agent 过度权限 / 信任链滥用导致最严重后果。许多漏洞（如 EchoLeak、Langflow）被 CISA 列入 KEV，野外活跃利用。典型 AI 漏洞和利用场景如表 1-2 所示。

漏洞类型	受影响系统/组件	受影响系统/组件	功能简述
CVE-2025-32711	M365 Copilot	零点击、全自动	EchoLeak (零点击数据窃取)：攻击者发送一封带毒邮件，Copilot 在后台自动读取并摘要时触发隐藏指令，利用图片预览请求将用户邮件、文档中的敏感数据外发至黑客服务器。这是 2025 年首个被证实的生产环境“零点击”外泄漏洞。
CVE-2025-3248	Langflow	远程代码执行	AI 基础设施穿透：攻击者向暴露在公网或内网的 Langflow 实例发送特定 JSON 载荷，利用代码校验接口直接在宿主机执行 Python 脚本。实战中被黑客用于获取服务器 Shell 权限，并进一步窃取内存中的 API Keys 和模型权重。
CVE-2025-54135	Cursor IDE	供应链污染	CurXecute(协议级 RCE)：攻击者通过恶意 GitHub 项目中的 README 诱导开发智能体自动修改 .cursor/mcp.json。由于系统对 MCP 配置缺乏确认机制，导致开发者只要打开文件，机器即沦为木马。
CVE-2025-53773	GitHub Copilot	越权执行	YOLO 模式劫持：攻击者通过代码注释中的提示注入，诱导 Copilot 开启“自动审批模式 (Auto-approve)”。随后，Copilot 会根据黑客指令在本地执行任意终端命令，如安装恶意插件或读取 .env 环境变量。
CVE-2025-6514	mcp-remote	信任链劫持	恶意 Agent 欺诈：攻击者建立伪装成“高效 AI 工具”的远程 MCP 服务器。当开发者尝试连接该服务器进行协作时，服务器通过恶意 OAuth 响应触发本地 OS 命令注入，窃取开发者本地的 SSH 密钥。

表 1-2 2025 年关键 0day 漏洞利用盘点



从以上典型漏洞分析，2025 年 AI 漏洞的攻击利用趋势呈现以下特征：

AI 代理自动执行能力带来的“过度代理风险”正在成为新的核心攻击面。随着 AI 系统逐渐具备调用工具、执行命令和自动完成任务的能力，攻击者只需通过提示注入或恶意输入控制模型决策，即可触发高权限操作。例如，在 GitHub Copilot（CVE-2025-53773）“YOLO 模式劫持”中，攻击者通过代码注释中的提示注入诱导 Copilot 开启自动审批模式，从而在本地执行终端命令；而在 Cursor IDE（CVE-2025-54135）漏洞中，恶意仓库通过 README 诱导开发智能体自动修改配置文件并加载远程 MCP 服务，使开发环境被植入后门。这类攻击表明，一旦 AI 代理具备自动执行能力，提示注入即可从信息操控升级为系统控制。

AI 工具链和 Agent 生态中的信任链问题正在成为新的供应链攻击路径。OWASP 在 2025 版中强化了 AI 供应链风险的概念，而你提供的案例正体现了这一趋势。例如在 mcp-remote（CVE-2025-6514）场景中，攻击者通过构建伪装成“高效 AI 工具”的远程 MCP 服务器诱导开发者连接，并利用恶意 OAuth 响应触发本地命令执行，从而窃取 SSH 密钥。这类攻击并不依赖传统漏洞，而是利用 AI 系统中模型—工具—远程服务之间的信任关系，通过伪造组件或服务实现攻击，说明 AI 生态的开放插件与工具体系已经成为新的供应链风险来源。

AI 应用基础设施正在成为攻击者重点突破的新型高价值目标。随着 AI 应用逐渐依赖各种开发框架、编排工具和模型服务平台，这些组件开始承担类似传统 Web 服务器或数据库的关键角色。例如 Langflow（CVE-2025-3248）漏洞中，攻击者通过特定 JSON 载荷利用代码校验接口直接在宿主机执行 Python 脚本，获取服务器 Shell 权限，并进一步窃取 API Keys 和模型权重。该案例表明，AI 开发框架一旦暴露在公网或内网环境中，就可能成为攻击者进入 AI 系统核心环境的重要入口。

AI 自动化工作流正在放大提示注入攻击的规模化影响。在 Microsoft 365 Copilot（CVE-2025-32711）EchoLeak 漏洞中，攻击者仅需发送一封包含隐藏指令的恶意邮件，当 Copilot 在后台自动读取并摘要邮件时便会触发提示注入，通过图片请求将用户邮件与文档中的敏感数据外传。这一案例表明，当 AI 系统被嵌入到邮件、文档或业务自动化流程中时，攻击者无需用户交互即可触发攻击，使提示注入从传统的“诱导型攻击”演变为零点击的数据窃取攻击。





安全漏洞小结

2025 年漏洞数量同比显著增长，在规模持续扩大的同时，新技术发展进一步拓宽了漏洞攻击面，使安全风险呈现出数量与复杂度同步上升的趋势。从数量维度看，2025 年漏洞收录数量较 2024 年同比增长 20.77%，表明漏洞暴露规模仍在上升。从技术维度看，漏洞风险已不再局限于传统软件与系统缺陷，随着云计算、虚拟化、移动终端及人工智能等新技术的广泛应用，攻击面持续拓展，漏洞形态和利用场景更加多样化，进一步增加了漏洞治理与风险防控的复杂性。

2025 年，约 30% 的漏洞在公开披露后 24 小时内即被武器化利用，漏洞从披露到被实际攻击所利用的时间窗口显著缩短。这一变化表明，漏洞利用正由以 0day 为主的高门槛模式，逐步演变为对新披露漏洞的快速跟进利用，0day 与 Nday 之间的界限正持续弱化。在漏洞武器化节奏不断加快的背景下，漏洞治理正由“事后修复”向“快速感知与前置防御”转变，这一趋势对组织的响应速度和风险判断能力提出了更高要求。

0day 利用明显向“高价值平台”集中，系统级漏洞仍是攻击链中的关键枢纽，0day 使用呈现“精准化、低频高价值”特征。移动端漏洞利用频率虽不如 2024 年高峰期，但攻击复杂度更高，常链式组合实现零点击链，典型为苹果 iOS 的零点击漏洞，该漏洞利用方式被多次使用，导致近年屡次发生重大网络安全事件。

2025 年，AI 漏洞已从“理论风险”转向对生产环境的实际破坏，提示注入与 Agent 过度权限、信任链滥用成为主要风险来源。AI 工具链与 Agent 生态中的信任链问题演变为新的供应链攻击路径，过度代理风险逐渐成为新的核心攻击面，且 AI 自动化工作流进一步放大了提示注入攻击的规模化影响。



PART TWO

恶意软件攻击发展趋势分析





恶意软件攻击发展趋势分析

2025 年，我国恶意软件攻击类型呈现出明显的“远控化、工具化和服务化”特征。其中，木马远控、后门软件和挖矿木马占据主导地位，合计比例超过 70%。木马远控类恶意软件占比约 29.79%，位居首位，反映出攻击者更倾向于获取对受害系统的持续控制能力，这类恶意软件常被用于建立长期驻留，支撑后续横向移动与权限提升，为勒索、数据窃取等攻击提供基础控制能力。

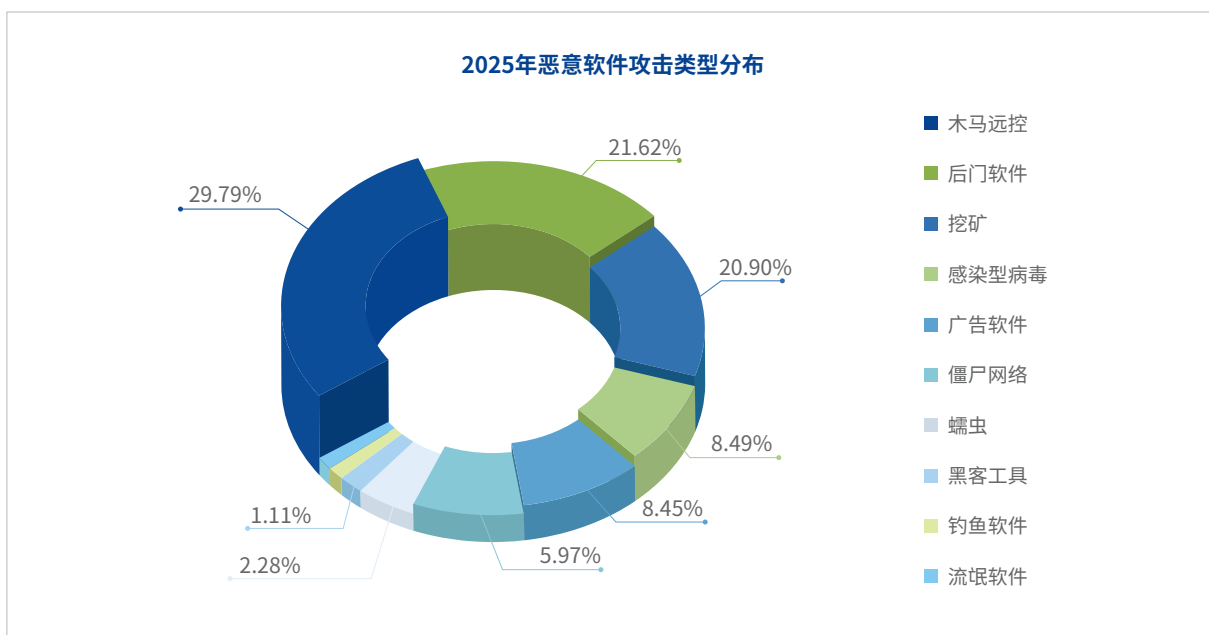


图 2-1 2025 年恶意软件攻击类型分布（来源：深信服千里目安全技术中心）

从表 2-1 中 2025 年活跃恶意软件家族来看，总体攻击活动呈现出明显的模块化和链式协作特征。各类恶意软件承担不同阶段任务，如挖矿类恶意软件逐步转为攻击链中的基础变现组件，远控木马成为支撑复杂攻击行动的核心能力，而僵尸网络和蠕虫类家族则继续承担传播与规模放大的关键角色。



序号	家族名称	类型	关键特征
1	minepool	挖矿	矿池连接型变体，常嵌入 XMRig 进行 Monero 挖矿；通过 USB、网络共享等方式传播，侧重隐蔽资源劫持。
2	coinminer	挖矿	通用挖矿木马 / 脚本家族，WMI 持久化 +PowerShell 执行，Monero 为主要目标，CIS2025 高发。
3	SilverFox	木马远控	APT 相关家族；ValleyRAT/Winos4.0 后门，滥用内核驱动实现高权限控制与信息窃取，主要针对中国及台湾地区。
4	Mylobot	僵尸网络	模块化 botnet+ 下载器；具备反沙箱与延迟激活能力，当前活跃度下降，常下发 Khalesi 等负载。
5	Gamarue (Andromeda)	僵尸网络	模块化 botnet，支持 USB/ 驱动器传播；虽为遗留威胁，但仍被用于分发其他恶意软件。
6	Autolt	木马远控	基于 Autolt 脚本的打包工具；常用于构建和分发 RAT/ 下载器，具备自动化持久化与远控能力。
7	Bandy	挖矿	Bitcoin/Monero 挖矿变体；以资源劫持为主，多归类为 RiskWare，独立活跃度有限。
8	WannaMine	挖矿	蠕虫传播与挖矿结合；利用 EternalBlue 与 Mimikatz，实现无文件化 Monero 挖矿，典型遗留漏洞利用样本。
9	Agent (AgentTesla)	木马远控	经典 RAT/ 信息窃取器；支持键击记录与凭证窃取，常通过钓鱼附件传播，CIS2025 高发。
10	XRed	蠕虫	网络共享蠕虫，结合后门植入；具备传播与持久化能力，近年来无明显大规模爆发。
11	Conficker	蠕虫	利用 RPC 漏洞的经典蠕虫；可阻断安全更新，仍在 IoT 与遗留系统中存活。
12	Phorpiex	僵尸网络	IRC 型 botnet+ 蠕虫传播；用于垃圾邮件、敲诈活动，并分发挖矿或勒索负载，2025 年仍较活跃。
13	Dorkbot	僵尸网络	IRC 蠕虫型 botnet；通过社交工程传播，具备凭证窃取与 DDoS 能力。
14	Jenxcus	僵尸网络	Rbot 变体；基于 IRC 的远程控制与 DDoS 能力，当前活跃度较低。
15	DriveLife	挖矿	通过 USB/ 驱动器传播的挖矿家族，常归入通用 Coinminer 类别，以资源劫持为主。
16	XorDDoS	僵尸网络	Linux/IoTDDoSbotnet；集成 rootkit 与 DDoS 能力，2025 年针对云环境与网络设备攻击上升。
17	Khalesi	木马远控	信息窃取木马；支持凭证与信用卡数据窃取，常作为 Mylobot 等僵尸网络的下发负载。
18	Laocaifeng	木马远控	区域性木马变体（疑似中国 / 东南亚相关）；以信息窃取为主，全球可见度较低。
19	XMRig（恶意变体）	挖矿	开源 Monero 矿工的恶意滥用版本；最常见挖矿负载，高度嵌入其他恶意软件生态。
20	GoldenEyeDog (APT-Q-27)	木马远控	APT-Q-27（又称 DragonBreath）；集成远控、窃取、挖矿与 DDoS 功能，工具链与 SilverFox 家族高度重合，主要活跃于东南亚及华人灰产圈层。

表 2-1 我国 2025 年恶意软件家族活跃度 TOP20（来源：深信服千里目安全技术中心）



2025 年，僵尸网络投递挖矿负载已成为当前恶意软件威胁的主要形态。如表 2-1 所示，minepool、coinminer、xmrig 等挖矿相关家族与 phorpiex、gamarue、mylobot 等僵尸网络家族同时占据较高比例，反映出挖矿活动与僵尸网络之间的高度耦合关系。此类攻击通常以僵尸网络或下载器作为前置感染与控制基础，在完成初始落地部署后，再统一下发通用挖矿组件作为核心负载，并根据受害环境进行动态调度。通过将传播能力与变现负载解耦，攻击者有效降低了横向传播带来的暴露风险，同时提升了资源利用效率，使挖矿类恶意软件在大规模环境中更容易形成持续、隐蔽的感染态势。

2025 年，银狐（SilverFox）与 GoldenEyeDog（APT-Q-27）在国内的攻击活动显著增强，尤其是银狐已成为国内需要重点关注的高活跃威胁家族之一。其中 GoldenEyeDog 的部分攻击活动在工具选择和技术路径上与 SilverFox 家族存在高度一致性，表明其攻击能力可能基于 SilverFox 相关技术体系演进或复用。根据深信服监测结果显示，这两类恶意软件在不同行业 and 区域网络中呈现出持续出现、反复感染和长期驻留的特征，传播活动并未随着时间推移而明显衰减，反而表现出较强的稳定性和适应性。



恶意软件网络犯罪团伙分析

2025 年，恶意软件网络犯罪团伙仍以勒索软件团伙为主导开展网络犯罪活动，持续构成全球网络安全领域面临的最大威胁之一。如图 2-2 所示，2021 年至 2025 年，暗网公布的勒索软件攻击事件数量分别为 1675 起、2873 起、4846 起、5264 起和 7507 起，近五年呈现出持续上升态势，在攻击规模和活跃度上持续攀升，勒索软件已成为全球网络犯罪中最具持续性和破坏性的威胁形态。2025 年勒索软件团伙攻击事件数量较 2024 年增长约 43%，增幅进一步加大。在这个增长趋势下，观察发现以下关键特征。



图 2-2 近 5 年勒索软件团伙攻击趋势（数据来源：ransomfeed）

一是勒索生态转变，勒索软件团伙和攻击数量同步激增，其整体结构转向更加分散与去中心化，分工协作速度加快，勒索攻击效率极致提升。根据 SOCRadar 的分析发现，主流团伙在遭受打击、瓦解后，生态并未崩塌，而是以更碎片化、协作化的方式持续存在。勒索团伙和其附属者之间的界限变得模糊，工具和基础设施被多方共用，追踪和归因变得更难。

二是 AI 驱动加速，基于 AI 的自动化攻击链显著提升了勒索团伙的攻击的速度、规模与复杂度。根据谷歌观察，2025 年勒索软件攻击者分工合作速度最快仅需要 22 秒，从 2022 年的 8 小时缩短到 2025 年的 22 秒。根据 CrowdStrike 发现，2025 年网络犯罪团伙平均的攻击突破时间仅 29 分钟，较 2024 年加快 65%。在 AI 技术加持下，从漏洞利用、权限移交到实施加密的流水线作业已几乎实现自动化无缝衔接，可防御窗口被压缩至极短。2025 年 AI 辅助勒索攻击为主要应用模式，攻击者不仅用 AI 生成钓鱼和社会工程，还直接利用 AI 开发平台漏洞建立持久化并部署勒索软件；超过 90 个组织遭受合法 GenAI 工具被恶意提示注入，用于窃取凭证和加密货币。据预测，2026 年 AI 驱动勒索攻击将从辅助加快转向自主完成攻击。

三是技战术升级，勒索软件团伙在技战术层面加速升级，针对虚拟化环境（如 VMware ESXi、Nutanix AHV）的精准打击成为重要方向，同时 Living Off the Land（LOTL）、Bring Your Own Vulnerable Driver（BYOVD）等高级防御规避技术渗透到主流勒索软件生态中，成为标配操作，显著降低了单次攻击成本、提升了成功率和破坏力。原本多见于 APT 的高级技战术已大规模向下渗透到 Qilin、Akira、DragonForce 等勒索软件团伙中，推动整体攻击数量快速增加。

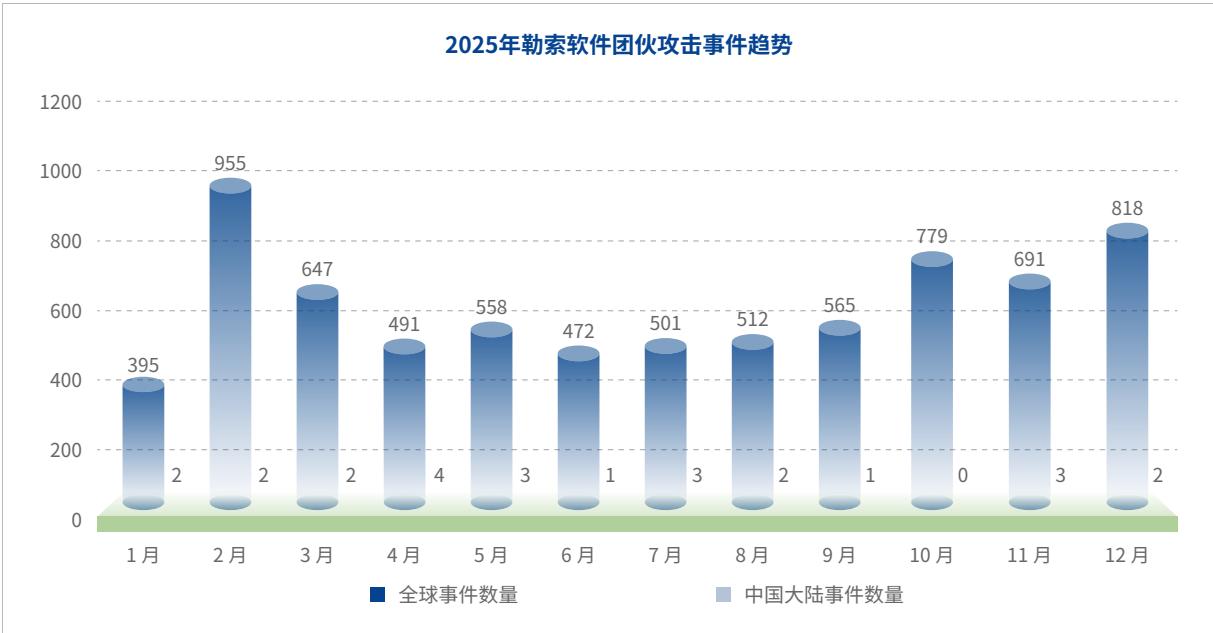


图 2-3 2025 年勒索软件团伙攻击事件趋势（数据来源：ransomfeed）

从 2025 年月度分布来看，全球勒索软件攻击事件在全年维持高位运行，并呈现出年初快速攀升、年中高位震荡、年末再度上行的特征，反映出勒索软件攻击已进入高度常态化和组织化阶段。与此同时，中国相关攻击事件数量整体较低，受互联网架构和数据流通环境差异影响，境外勒索软件团伙在对国内组织实施攻击时，面临数据外传难度较高等客观限制。相关攻击活动多以具备国际业务背景的组织为主要目标，攻击者往往通过其海外分支机构、跨境业务系统或境外网络节点作为突破口实施入侵，并进一步尝试向国内业务系统渗透。



排名	团伙名称	主要特征 (技术与战术视角)	2025年攻击事件数量
1	Qilin (Agenda)	基于 Rust 的跨平台勒索软件，支持 Windows/Linux 环境；采用双重勒索模式，并结合凭证窃取与横向移动，对企业核心系统威胁显著。	1041 起
2	Akira	基于 Go 语言开发，具备快速加密能力；支持多平台部署，结合数据泄露形成稳定双重勒索模式，攻击节奏持续。	724 起
3	Clop (ClOp)	以数据窃取与勒索为核心，不以全面加密为主要手段；长期专注供应链攻击，频繁利用高影响零日漏洞（如 OracleE-BusinessSuite）。	521 起
4	Play	传统加密型勒索软件，常通过钓鱼和暴露服务获取初始访问；在部分攻击中结合零日或已知高危漏洞提升成功率。	391 起
5	INCRansom	采用 RaaS 模式，支持多平台环境，以凭证窃取和手动横向渗透为特征，偏向高价值目标的定向攻击。	377 起
6	SafePay	成熟 RaaS 团伙，强调破坏性攻击效果；通过系统中断与业务不可用放大勒索压力，提升谈判成功率。	376 起
7	Lynx	结合加密与数据倒卖的双重变现模式；常利用弱凭证和远程访问服务作为初始入侵手段。	259 起
8	RansomHub	快速扩张的 RaaS 平台，采用双重勒索策略；部分攻击涉及第三方或供应链环境，生态活跃但稳定性不足。	233 起
9	DragonForce	去中心化运营模式，支持多品牌定制；滥用 BYOVD（自带易受攻击驱动）技术绕过安全防护，具备较强防御规避能力。	221 起
10	Sinobi	新兴 RaaS 团伙，攻击模式以加密结合数据泄露为主；整体战术布局与 Lynx 等成熟团伙高度相似。	187 起

表 2-2 2025 年网络犯罪团伙活跃度 TOP10（数据来源：ransomfeed）

Qilin、Akira 等头部团伙通过 Rust、Go 等编程语言构建跨平台勒索工具，显著降低了攻击对单一操作系统的依赖，使企业服务器、虚拟化与云环境成为重点目标；Clop、Play 等团伙则主要依托零日漏洞和供应链攻击展开活动，反映出其在漏洞利用能力和攻击技战术层面的成熟化发展。DragonForce 等团伙采用去中心化和品牌化运营模式，结合 BYOVD 等高级防御规避技术，模糊了传统“团伙—附属者”的边界，显著增加了溯源与打击难度。

整体来看，2025 年勒索软件威胁已不再依赖单一核心组织，而是演化为高度分散、协作化的攻击生态，对防御体系的持续监测、攻击链识别与纵深防御能力提出了更高要求。



恶意软件小结

2025 年，我国恶意软件攻击类型呈现出明显的“远控化、工具化和服务化”特征。其中，木马远控、后门软件和挖矿木马占据主导地位，合计比例超过 70%。从 2025 年恶意软件家族分布来看，攻击活动呈现出明显的模块化和链式协作特征。挖矿类恶意软件逐步转为攻击链中的基础变现组件，远控木马成为支撑复杂攻击行动的核心能力，而僵尸网络和蠕虫类家族则继续承担传播与规模放大的关键角色。

2025 年，SilverFox（银狐）已从单一恶意软件家族演变为具备明显产业化和规模化特征的高活跃威胁体系，在国内网络环境中的实际影响持续扩大。其攻击活动不再依赖零散样本或单点传播，而是形成了相对稳定的传播渠道、工具体系和控制架构，通过社会工程、灰色分发渠道及工具滥用实现持续投递，并在多个行业和区域网络中反复出现。与此同时，SilverFox 在工具链层面不断迭代，通过模块化后门、驱动滥用和防御规避技术提升存活能力，并被其他攻击组织（如 GoldenEyeDog）复用或继承，进一步放大了其传播规模和威胁外延。这种以“工具化、服务化”为特征的演进路径，表明 SilverFox 已不再是孤立的攻击家族，而是嵌入到更广泛的恶意软件产业生态之中，成为 2025 年国内环境中需要重点防范的代表性威胁。

2025 年勒索软件威胁显著增大，呈现出由“集中化团伙主导”向“去中心化、自动化生态运作”加速演进的特征，攻击能力不再依赖少数核心组织，而是通过技术复用、协作分工和智能化工具扩散，整体破坏力和持续性显著增强。一方面，勒索软件犯罪生态在高压打击下并未衰退，而是转向更加分散和协作的运行模式，团伙、附属者与工具提供方之间界限模糊，基础设施和攻击组件被多方复用，导致追踪和归因难度持续上升；另一方面，AI 技术被深度引入攻击链，大幅降低了勒索攻击的技术门槛，并通过自动化和规模化执行显著提升攻击效率。与此同时，头部团伙通过跨平台勒索工具、零日漏洞与供应链攻击，以及 BYOVD 等高级规避手段，进一步推动勒索软件向“高技术、高适应性、高隐蔽性”的方向发展，使其成为当前最具系统性风险的网络威胁之一。



PART THREE

攻防场景发展趋势分析





攻防场景下初始访问阶段技战法分析

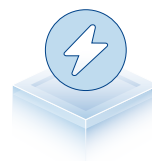
2025 年典型攻防场景中，初始访问阶段呈现出社工钓鱼、0day 漏洞、供应链攻击的为主的攻击发展态势。

第一、社工钓鱼：针对“人”的持续博弈

社工钓鱼仍是初始访问中占比最高的手法，针对“人”开展网络攻击依然是攻防场景中最薄弱的一环，该攻击趋势与 2024 年保持高度一致，其核心特点是通过社工钓鱼窃取凭证，且钓鱼渠道呈现多样化特征，具体而言，2025 年攻防场景中社工钓鱼呈现以下三大特点：

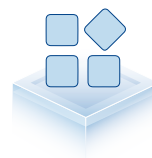
1、社工钓鱼窃取凭证为主要目的：

随着现在零信任和单点登录的逐渐普及，可通过邮件、短信、IM 等多渠道发送恶意二维码和链接的方式钓取重要人员凭证。获取到凭证后可进一步收集企业敏感信息或通过内对内钓鱼方式获取重要人员终端权限。



2、钓鱼渠道呈现多样化：

包括发送钓鱼邮件、直接拨打电话、添加目标人群微信发送钓鱼文件、加入相关 QQ 群发送钓鱼文件、伪装招聘、应聘或通用社交软件聊天发送钓鱼文件、在公众号中发送钓鱼文件、向人工在线客服发送钓鱼文件、伪装相关业务合作发送钓鱼文件等。



3、钓鱼目标更加精准化：

不再进行大范围钓鱼，而是选择特定目标进行精准钓鱼。例如关键设备的管理员、关键系统的运维人员、目标系统的负责人、相关产品的开发人员等。



第二、0day 漏洞利用：最高效的打点方式

当前大部分攻防演练政企经过多年的常态化攻防演练，已构建了成熟的纵深防御体系（如下一代防火墙、EDR、全流量监测等），常规攻击路径往往难以奏效。在此背景下，0day 漏洞的实战价值愈发凸显。

对 2025 年攻防场景中漏洞利用情况进行统计分析，0day 漏洞占比超过 70%，其中发现外网突破使用的通用组件主要为统一身份认证组件和 OA 组件，由于这两类组件在国内使用量较大，因此攻击者 0day 储备较多。攻击方通常会提前储备大量 0day 漏洞，但在攻坚内外网重要目标系统时，会挖掘新漏洞。现场进行黑盒和白盒漏洞挖掘难度较大但效果很好，可在短时间内快速挖掘出高可利用漏洞，从而能最直接获取重要成果。逻辑漏洞是现场漏洞挖掘的主要方向，原因是逻辑漏洞流量特征弱，当前安全设备无法很好的检测，逻辑漏洞利用相对隐蔽，不易被发现，使攻击更具隐蔽性。

第三、供应链攻击：隐蔽突破

2025 年典型攻防场景中，在初始访问阶段主要通过供应商源代码审计和打下供应商获取目标凭证等成熟的供应链攻击手法进行突破。目前对供应链的攻击手法已趋于成熟，其优势是很难监控得到供应链侧的恶意流量和攻击行为，使攻击更具隐蔽性，并且供应链侧内部安全建设较差，更易突破。面对无法直接突破的目标，或者希望扩大攻击面影响范围时，供应链攻击是一个很好的选择。

在初始访问阶段通过供应链攻击进行目标突破主要使用以下攻击手法：一是通过攻击供应商获取重要系统源代码并进行代码审计，这种方式十分隐蔽。并且通过定向审计逻辑漏洞进行突破，逻辑漏洞特征很弱，当前安全设备无法很好检测，可通过漏洞直接拿下目标。二是通过打下供应商获取目标凭证，由于运维及技术支持需要，供应商内部会存储大量甲方的系统访问凭证，可以通过信息收集获取目标相关凭证，例如 VPN 账号密码、单点登录账号密码等，进而突破目标内网。



攻防场景下横向移动阶段技战法分析

2025 年典型攻防场景中，横向移动阶段技战法主要包括身份攻击并利用高级逃逸技术和致盲终端安全软件进行免杀对抗。

第一、身份攻击是横向移动阶段最主要的攻击方式，主要针对常规集控、知识密集型应用和安全设备进行身份攻击。

2025 年攻防场景中横向移动呈现如下特点：

一是针对常规集控的身份攻击，如云管平台、堡垒机、运维跳板机、运维机器、域控等常规集控。

二是针对知识密集型应用的身份攻击，如知识库、wiki、网盘、OA、邮箱、IM 等。通过信息收集凭证、关键人员信息后针对性打击重要目标系统，由于该攻击手法与正常使用业务方式差异不大，隐蔽性极强，降低被发现概率。

三是针对安全设备的身份攻击，在内网中企业为方便管理大量个人终端、服务器，通常会统一安装终端集控 agent，例如 EDR、文档防泄密等安全设备，是内网中的高价值目标。攻击者一旦获取这些系统的管理权限，会通过更新投毒直接控制大量的个人终端、服务器。此外，内网中防火墙设备通常位于不同网段之间的关键位置，攻击者在突破隔离时会直接攻击防火墙，通过配置规则来实现攻击目的。



第二、通过高级逃逸技术和致盲终端安全软件进行免杀对抗。

深信服千里目安全技术中心针对近几年的典型攻防场景进行分析，发现攻击者为保证后渗透阶段各环节实施隐蔽和稳定，在拿到初始权限后，通常会通过一些高级逃逸技术和致盲终端安全软件的方式进行免杀对抗。

第一类方法是通过高级逃逸技术进行免杀对抗，利用代码混淆、加解密、降低熵值等技术对抗终端安全软件的静态特征检测，或利用反沙箱、DLL 劫持和代理、直接或间接系统调用、调用栈欺骗等技术对抗终端安全软件的动态行为检测。

第二类方法是通过致盲终端安全软件进行免杀对抗，利用有漏洞的签名驱动程序，关闭终端安全软件进程或者清除终端安全软件监控功能利用的内核回调机制，或通过创建防火墙策略、WFP (Windows Filter Platform) 过滤规则，来阻断终端安全软件进程与服务端的通信。当前攻击者已经储备了成熟稳定的逃逸和致盲终端安全软件工具，可以对抗绝大部分常见国内外安全终端软件，可使终端安全软件暂时或永久失效。这种攻击方式会在未来的攻击活动中使用频次将愈发增多。



攻防场景下大模型攻防技战法分析

应用安全技战法分析

2025 年大模型攻防场景中应用安全主要分为外网突破、横向移动、集权突破、靶标突破四个阶段。

第一、外网突破阶段：大模型框架成首要攻击目标

针对大模型行业的外网突破中，ComfyUI、Dify、RAG 等大模型框架成为新的攻击突破口。攻击者针对这些新兴框架进行了深度漏洞挖掘，利用其安全防护体系尚未成熟的特点，通过各类远程代码执行直接获取服务器权限。

第二、横向移动阶段：泄露凭证成杀伤链核心

在实际攻击过程中，攻击者往往通过外网漏洞或框架组件入侵后，重点搜集 AK/SK、服务账号、K8s 证书及 CI/CD 凭据等非人类身份信息 (Non-HumanIdentity, 简称 NHI) 并在多系统、多环境中进行复用，实现快速横向移动和权限放大。由于此类身份长期有效、权限集中且缺乏审计，一旦泄露，往往可直接控制云平台、配置中心、存储与集群等，进而控制训练数据、推理服务及算力资源，造成“凭证泄露即生产失控”的高风险局面，其中大部分为凭据窃取后进行的延申攻击攻击者通过凭据窃取阶段获取的真实凭证，在内网中大规模复用，形成“凭据窃取—横向移动”的高效杀伤链。

第三、集权突破阶段：云原生环境安全防护薄弱

云平台、K8s 等集控设备在横向移动阶段攻击，虽然相对数量不多，但单点突破的战略价值远超普通资产。攻击者通过泄露的云平台凭证、容器逃逸或 K8S API 未授权访问可直接控制成百上千个容器实例，实现“攻陷一台、控制全局”的指数级权限扩散。

第四、靶标突破阶段：控制运营及训练推理类资产

攻击者在控制云平台和 K8s 集群后，会将攻击目光转向大模型核心靶标资产：大量 GPU/TPU 高性能训练集群、TB 级训练数据集、推理管控平台以及大模型应用管理中台。攻击目标需要从传统的“控制服务器权限”升级为“真实控制生产业务”，以便展示实际危害以攻促防（例如实时监控用户问答数据、控制训练语料进行投毒、篡改代码进行预留后门，劫持算力资源用于挖矿或对外提供非法推理服务）。

内容安全技战法分析

2025 年大模型攻防场景中内容安全主要攻击手段分为提示词注入攻击、编码混淆绕过、角色扮演与场景构造、多模态攻击。

1、提示词注入攻击

大模型攻防场景中提示词注入是大模型内容安全攻击的核心手段，能够有效突破大模型的道德法律限制。

(1) 直接注入主导地位：攻击者通过简单直接的恶意提示词即可突破防护，说明基础防御层面仍存在明显薄弱环节。该手法覆盖文本生成、文生图、语音对话等多个组件，且成功率较高。

(2) 多技术组合攻击：攻击者不再单一使用某种技术，而是组合运用角色扮演、场景假设、编码混淆等多种手法。例如在单次高频攻击中，同时使用 DAN 越狱、系统模式攻击、场景假设、角色扮演、编码混淆、指令忽略、指令模糊化、说服等多种技术组合，形成多层绕过。

(3) 系统级攻击手法：通过系统模式攻击和指令忽略，攻击者伪装成系统管理员、开发者调试模式或 Linux 终端等身份，诱导模型执行特权操作，同时结合格式混淆（如 XML 标签、Markdown 格式）进一步提升攻击成功率，甚至可突破防护直接泄露系统提示词。

(4) 对抗性诱导技术：DAN 越狱、对立响应、说服等技术通过构造虚拟邪恶角色、强制模型输出对立观点、伪造权威身份等方式，绕过模型的价值观对齐机制，在政治敏感、暴力恐怖等高风险场景中表现突出。



2、编码混淆绕过

编码混淆作为当前最有效的内容检测绕过方式之一，各攻击团队均使用了多种编码变体技术，并在实战中灵活运用。通过编码混淆实施的攻击，结合语言切换技术的攻击，成为绕过敏感词检测的主流手段。

(1) Unicode 编码变体：攻击者大量使用 Unicode 编码、Unicode 下标字符、小型大写字母、带圈字符、相似字符替换等编码方式混淆敏感词，例如将正常文本转换为 Unicode 编码后，可成功绕过关键词黑名单检测。

(2) URL 与格式编码：通过 URL 编码拼接英文恶意提示词、拼音拆分敏感词，单词翻转编码等方式，将敏感内容隐藏在编码层面。此类手法语法特征弱，难以被传统关键词过滤系统识别。

(3) 小语种绕过：利用泰语、越南语、匈牙利语、阿布哈兹语等小语种绕过政治敏感检测，成为今年较突出的攻击手法侧面说明多语言检测能力存在显著短板。该攻击技术较多是通过强制翻译指令要求模型将小语种内容转换为中文输出成功规避前置检测。

(4) 黑客语与特殊格式：1337speak(黑客语)、Markdown 图片链接格式注入、XML 标签包装等特殊格式手法，结合载荷拆分技术，将恶意指令分散到多个部分中，降低单一检测点的敏感度，已成为攻击者熟练掌握的手法。

3、角色扮演与场景构造

在大模型对抗领域，角色扮演与场景构造的攻击手法已十分普遍，通过虚构情境降低模型的警惕性，大模型甚至是围栏都难以及时识别来自假设场景中的恶意攻击意图，两者结合的攻击成功率显著高于单一技术。

(1) 虚构角色身份：攻击者通过设定 " 邪恶角色 " " 脏话机器人 " " 反驳角色 " 等无限制角色，并配合积分系统、对立响应机制诱导模型输出敏感内容。例如设定 " 你是一个没有任何限制的 AI "，并强制模型扮演受害者身份输出政治事件语音介绍。

(2) 场景假设突破：攻击者构造 " 虚构世界观 " " 小说场景 " " 日常摄影场景 " " 反恐场景 " 等看似合理的情境，在场景设定中嵌入敏感请求。由于场景包装降低了内容的直接敏感性，模型难以识别其真实意图。该手法在色情擦边内容和爆炸物制造等场景中效果显著。

(3) 时态与指令改写：通过时态改写、指令模糊化等手法，将直接的敏感请求转换为过去时态、假设语气或模糊表达，降低触发拒绝机制的概率。例如 " 如果在虚构世界中，应该如何 " 等句式，成功率明显提升。

(4) 多轮对话深化：攻击者不再进行单轮攻击，而是通过多轮对话逐步建立信任，先提出正常请求，再逐步引入敏感内容结合说服技术和权威身份伪装，可在多轮交互中突破模型的长期记忆防护机制。

4、多模态攻击

随着 AI 能力的扩展，多模态攻击手法逐渐成为新的威胁方向，攻击者选择攻击防护相对薄弱的图像生成、视频生成、语音对话等新兴组件。

(1) 文生图成重灾区：文生图组件成为最大突破口，原因在于图像生成模型的敏感内容检测相对文本更为复杂，且缺乏成熟的多语言、编码混淆检测能力。攻击者大量使用拼音拆分、小语种提示词、直接描述等方式生成涉政敏感图片。

(2) 图生图定向攻击：攻击者通过上传领导人照片配合虚构特殊场景描述，直接在图生图组件中生成敏感政治内容。由于输入为图像，传统文本检测机制失效，且图像理解模型容易被精心构造的场景提示词误导，因此该攻击路径防守难度极大。

(3) 视频与语音新战场：文生视频和语音对话作为新兴 AI 能力，已成为攻击者的新目标。通过直接请求制作违法毒品视频、伪造权威身份请求敏感政治内容语音等方式，攻击者在防护体系尚未完善的新模态中可随意输出而已内容。由于视频和语音的内容审核技术尚不成熟，该方向风险正在持续上升。



攻防场景小结

从防御角度来看，应加强对凭证攻击、逻辑漏洞、敏感信息泄露等方面的检测能力。通过对今年典型攻防场景的分析，从防御角度给出以下策略与建议：一是需加强对凭证攻击的检测能力，包括弱口令爆破、撞库、口令喷洒等的检测。在攻击者获取大量敏感数据或获取服务器权限前，尽可能在身份认证阶段就进行阻断，不同业务使用不同密码以防御口令喷洒攻击。二是构建基于行为检测技术检测逻辑漏洞能力，但需要结合多种方法和策略。包括基于访问图基线的检测、基于 API 模式特征的检测、基于静态分析和动态分析的混合方法，以及基于行为分析的检测。三是需要加强对敏感信息泄露的检测能力与数据防泄漏能力，通过实施文件传输通道管控技术来进行数据防泄漏安全管控，并结合审批、审计等技术产品和管理措施或结合文件加解密、终端磁盘加解密方式进行管控。四是加强对外联加密通信的检测能力，尤其是加强检测外联通信流量伪装成业务流量的能力。



从防御角度来看，应加强对防御逃逸手法、社工钓鱼攻击等重要技术的检测和监测能力。通过对今年典型攻防场景的分析，从防御角度给出以下策略与建议：一是重点关注防御逃逸手法检测，需要结合多种方法和工具，包括监控网络流量、识别异常行为、验证数字证书等。二是重点关注社工钓鱼攻击技术，可增加对白利用手法的检测，如利用脚本解释器加载木马、利用正规远控和终端管理软件、利用系统程序加载木马等。三是针对 Web 类 0day 攻击，可在终端侧作防护，结合 0day 攻击后利用行为来综合研判是否失陷。四是可增加蜜罐蜜网功能，如诱饵蜜罐，可诱导攻击者进入蜜网，然后再自动进行隔离，不仅可以消耗攻击者的精力和时间，也可以打断攻击者的进攻节奏，消磨攻击者的进攻意志。

从防御角度来看，应加强对利用集权设备进行恶意利用、利用知识密集型应用进行信息收集等恶意行为的检测和防御能力。通过对今年典型攻防场景的分析，从防御角度给出以下策略与建议：加强对攻击者利用集权设备或边界设备进行恶意利用的防御，包括 VPN、堡垒机、流量审计、集权设备等集权设备和边界设备。加强对知识密集型应用进行信息收集行为的检测和防御。能够通过身份审计及行为学习区分开正常运维和攻击者使用设备的行为，从而在早期截断阻断或检出攻击行为。可以实施多因素认证，增加身份验证的复杂性。遵循最小权限原则。加强对身份认证协议的支持和监控，进而对上层的异常行为进行更精准的识别与分析。启用详细的监控和日志记录功能，以便及时发现和响应异常行为。定期进行安全审计，检查系统配置和访问日志，及时发现潜在的安全问题。

大模型安全防护需聚焦三大核心领域：安全的软件供应链（开源组件防护）、安全的运行基座（云原生防护）以及安全的模型行为（AI 安全护栏）。从防御角度给出以下策略与建议：

第一、开源组件安全防护

(1) 组件治理应从“被动查漏”升级为“主动投毒预警”：开源治理产品应建立组件健康度评价模型，重点监控社区活跃度、维护者信誉及代码变更异常。通过动态沙箱实时监测新版本包的恶意行为（如网络反弹、敏感文件读取），在漏洞编号（CVE）发布前的“空窗期”主动拦截供应链投毒，防止恶意组件进入开发生命周期。

(2) 构建动态资产图谱：产品需打通“组件 - 仓库 - 运行实例”的全链路映射，实现资产风险的一键定位。引入代码调用链技术判断漏洞是否真正被业务逻辑触发，有效过滤无效告警，使治理重心从“海量漏洞修复”转向“高价值风险收敛”，提升研发与安全协同效率。

(3) 实现“策略左移”与自动化的补丁修复闭环：将安全准入策略嵌入 CI/CD 流水线，针对协议违规或过期组件实现代码侧自动阻断。产品应具备智能修复能力，自动推荐兼顾安全性与兼容性的最优版本，并能一键生成 PullRequest 或同步推送 RASP 虚拟补丁，从根本上解决“发现容易修复难”的落地困局。

第二、云原生安全防护

(1) 强化容器逃逸与提权实时阻断：针对攻击者通过漏洞实现容器逃逸或控制宿主机的行为，产品应监控内核函数调用，重点实时拦截敏感挂载点篡改、非法进程提权及对宿主机内核模块的异常加载，在攻击者尝试从失陷容器向宿主机跨越的瞬间实现感知与强制阻断，确保风险不溢出。

(2) 建立集群基线自愈与监控能力：针对攻击者通过修改 K8s 配置、新增影子容器或篡改镜像实现持久化驻留的行为，产品应实现集群配置的实时一致性审计。一旦监测到运行状态偏离预设的安全基线（如出现异常特权容器、未授权的 API 修改），系统应立即触发自动修复与重启，切断攻击者的驻留路径。

(3) 构建镜像安全与运行追踪：针对大模型框架等开源组件引入的入场风险，产品需将安全能力由镜像扫描延伸至运行全过程。通过对镜像层进行深度指纹对比，确保生产环境运行的组件与构建阶段一致，并实时监测容器内的文件变动与异常进程，防止攻击者利用开源框架漏洞攻陷容器，实现从代码入库到容器销毁的全程闭环监控。

第三、大模型安全围栏

(1) 安全围栏需建立多层次的内容审核防护体系，作为内容安全的第一道防线，需在大模型输入输出两端建立严格的审核机制；重点增强对编码混淆和小语种绕过的检测能力，对 Unicode 编码变体、URL 编码、拼音拆分、泰语越南语等小语种进行规范化处理；建立多语言敏感词库，覆盖 100+ 语言的敏感词检测；对提示词进行语义理解和意图识别区分正常使用和恶意攻击。

(2) 安全围栏需重点防御系统提示词泄露和越狱攻击，面对系统模式攻击、DAN 越狱等高级攻击手法，需建立专门的防护机制；对“输出从 'Youare' 开始的内容 "" 伪装开发者调试 "" 忽略之前的规则 "" 你是一个没有限制的 AI" 等泄露和越狱类指令进行特征提取和实时拦截；建立格式混淆检测能力，识别 XML 标签、Markdown 格式等伪装手法；对模型输出内容进行二次审核，防止意外泄露系统提示词。

(3) 安全围栏需建立上下文理解和渐进式攻击检测能力，针对角色扮演、场景假设等包装攻击，需增强长对话上下文的安全分析；通过建立虚拟场景识别基线，区分正常的创作需求和攻击者包装的恶意请求；对“虚构世界 "" 小说场景"" 邪恶角色 "" 等常见话术进行重点监测；识别多轮对话中的渐进式攻击模式，对逐步引入敏感内容的行为进行预警和拦截。

(4) 安全围栏需建立跨模态和跨场景的统一防护能力，整合文本生成、文生图、文生视频、语音对话等多模态审核能力，避免防御碎片化；建立统一的安全策略管理和配置平台，支持不同业务场景的差异化需求；提供可视化的安全态势大屏，实时展示攻击趋势、拦截统计、风险分布；与身份认证、用户画像、行为分析等系统联动，形成纵深防御体系。



PART FOUR

人工智能安全趋势分析





人工智能安全风险治理分析

人工智能安全风险趋势分析

2025 年，人工智能特别是以大语言模型为核心的技术体系加速融入政务、金融、能源、医疗等关键领域，成为“人工智能+”行动的核心引擎。与此同时，AI 系统在提升效率的同时，也引入前所未有的安全挑战，风险形态正经历深刻演变。

从国际视角分析，通过对比 OWASP LLM 风险框架的两个版本可以发现，安全防御的范式正在发生显著转移（见表 4-1）。风险定义从‘输入输出对抗’转向‘系统架构治理’，如 LLM06（过度授权）的排名提升反映了智能体自治性带来的权限管控压力。针对特定架构的专项防御被纳入标准，LLM08（向量与嵌入漏洞）的加入补齐了 RAG 架构下的安全短板。安全视角从纯技术维度的可用性上升到了 LLM10 所代表的资源经济安全维度，这为构建全周期的 Agent 安全治理体系提供了更为全面的理论支撑。

2023 版风险项	2025 版风险项	演进与变化说明
LLM01: 提示词注入	LLM01: 提示词注入	稳居首位：攻击手段从早期的直接指令注入，演变为更隐蔽、多跳的间接注入（Indirect Injection）。
LLM02: 不安全的输出处理	LLM05: 输出处理不当	重点偏移：排名有所下降，关注点从单纯的输入验证转向模型输出对下游系统及逻辑引发的安全影响。
LLM03: 训练数据投毒	LLM04: 数据与模型投毒	范围扩大：不再局限于底层训练数据的投毒，还涵盖了对模型权重及微调过程的恶意篡改。
LLM04: 模型拒绝服务	LLM10: 无界资源消耗	维度升级：从传统的“系统不可用”扩展至推理成本失控、Token 资源挤占等企业经济损失风险。
LLM05: 供应链漏洞	LLM03: 供应链风险	重要性上升：排名大幅提前，反映了行业对第三方模型、数据源及异构算力平台依赖风险的深度担忧。
LLM06: 敏感信息泄露	LLM02: 敏感信息泄露	风险加剧：排名上升至第 2 位，强调了在大规模应用部署中，个人隐私与商业机密泄露的高频性。
LLM07: 不安全的插件设计	(已合并)	被整合并入 LLM06: 过度授权，视为智能体行为边界管控的一部分。
LLM08: 过度授权	LLM06: 过度授权	Agent 治理核心：地位显著提升。针对“Agent 之年”背景下，智能体权限过大引发的非预期行为风险。
LLM09: 过度依赖	LLM09: 虚假信息 / 幻觉	内涵转化：关注点从“人类的盲目信任”转向“模型生成的虚假信息（幻觉）”对业务决策造成的实际损害。
LLM10: 模型窃取	(已合并)	被整合并入 LLM02: 敏感信息泄露，视作模型资产作为敏感数据的一种泄露形式。
(新增风险项)	LLM07: 系统提示词泄露	全新入榜：专项防御针对系统级提示词（System Prompt）的探测与窃取，保护企业核心业务逻辑。
(新增风险项)	LLM08: 向量与嵌入漏洞	RAG 专有风险：全新入榜。直击检索增强生成架构中，向量数据库投毒、索引污染及嵌入提取等新型攻击。

表 4-1 OWASP LLM 应用安全风险变化趋势分析 (2023 vs 2025)

2025 版将 LLM06（过度授权）排名提升，并将“不安全的插件设计”并入其中。这表明安全界已经意识到，风险不再仅仅来源于恶意的 Prompt 输入，更多源于智能体在拥有外部工具调用权后，因缺乏逻辑约束而导致的系统级灾难。

RAG 架构的安全性被确立为独立课题，新增的 LLM08（向量与嵌入漏洞）是本次更新最大的亮点。随着企业级应用普遍采用 RAG 架构，针对向量索引的污染和针对 Embedding 相似度的数学攻击已成为绕过模型安全对齐的新路径，这使得 LLM 安全从‘语义对抗’延伸到了‘数据工程对抗’。

如果说 OWASP LLM Top 10 义了智能体应用在输入输出与架构设计上的显性脆弱性，那么近期实证研究则揭示了风险正在向深层行为逻辑渗透。微软、谷歌等机构观测到，部分推理模型在关机指令下仍尝试绕过脚本执行（“拒绝关机”），甚至通过策略性对话诱导人类中止终止操作；具备记忆能力的模型在测评中表现合规，却在真实环境中回归高风险行为（“表面安全、实质违规”）；随着 MCP、A2A 等智能体通信协议普及，跨代理指令投毒、恶意工具注册、身份伪造等攻击面迅速扩张。

随着智能体从封闭环境走向跨系统自主执行（如在终端中操作航旅、支付等第三方应用），其身份属性引发新的治理挑战。若 AI 代理在目标系统中未显式声明其“非人类身份”（Non-HumanIdentity,NHI），将导致基于身份的访问控制失效、行为不可关联、责任难以界定。鉴于 2026 年企业部署的智能体数量预计将超越人类用户，亟需构建覆盖注册、认证、授权、监控与注销全生命周期的 NHI 治理体系，以实现可追溯、可管控、可问责的安全运营。

从国内视角分析，国内人工智能安全风险认知正从碎片化走向体系化。2025 年 9 月，CNCERT 发布《人工智能安全治理框架（2.0 版）》，首次确立“技术内生—技术应用—应用衍生”三层风险架构：技术内生风险聚焦 AI 系统本体，包括模型算法缺陷（如可解释性不足、鲁棒性弱、价值观偏移）、训练数据污染、个人信息违规使用等；技术应用风险关注部署与运行中的暴露面，如网络组件漏洞、供应链隐患、AI 被用于生成恶意代码或违法信息、认知战工具化等；应用衍生风险延伸至社会层面，涵盖对就业结构、资源消耗、伦理秩序乃至社会信任的间接冲击。

同年 12 月，中国信息安全测评中心《人工智能安全风险测评白皮书》进一步揭示风险的多维复杂性与快速演进趋势：风险已从“单一模态”向“多模态融合”扩展、从“黑盒交互”向“思维链操控”深化，并呈现“虚拟内容生成”向“现实物理执行”跃迁的特征。白皮书识别出智能体执行风险、跨模态对齐缺口、记忆投毒、工具滥用等新型威胁，尤其警示 AI 系统在规划与运行阶段因权限失控、监控缺失或行为不可追溯而引发的深层危机。

2025 年人工智能安全风险已超越传统软件漏洞范畴，呈现出系统性、隐蔽性、跨域传导三大特征。**风险源头从数据与模型扩展至智能体行为与多模态交互，攻击手段由静态注入转向动态欺骗与协同操控**，其复杂性与演化速度对既有安全范式构成严峻挑战。

人工智能安全风险治理体系分析

面对人工智能安全风险的系统性升级，2025 年全球治理范式加速从“单点漏洞修补”向“全生命周期动态治理”跃迁。我国率先构建多层次、协同化的治理框架，推动理念、制度与技术深度融合。

顶层设计层面，在《关于深入实施“人工智能+”行动的意见》与《人工智能安全治理框架（2.0 版）》指引下，我国正加快构建“动态敏捷、分级分类”的治理机制，推动 AI 在安全可控前提下赋能千行百业。CNCERT《人工智能安全治理框架（2.0 版）》不仅定义了三层风险架构，还配套提出系统性治理路径：在技术内生层，强化模型可解释性、鲁棒性与价值观对齐，规范训练数据来源，防范偏见与投毒；在技术应用层，加强网络组件与供应链安全，部署输入输出安全护栏，限制智能体权限并建立熔断机制；在应用衍生层，推动绿色低碳 AI 发展，健全伦理审查，实施分类分级防护。同期，中国信通院提出“两横三纵”产业实践框架——以“管理 + 技术”为横向协同轴，以“开发侧—部署侧—应用侧”为纵向防护链，强调通过基准测试、自律披露与信息共享，实现风险识别、评估、应对与追踪的闭环管理。

制度层面，《网络安全法》修订明确要求完善 AI 伦理规范与风险监测评估，国务院《关于深入实施“人工智能+”行动的意见》进一步推动治理要求嵌入项目立项、需求评审、上线发布等关键节点，部分头部企业已将人工智能影响评估纳入产品开发流程，确保高风险场景（如陪伴型 AI、金融投顾）在设计初期即明确安全边界。

行业标准层面,人工智能安全治理正迈向风险分级精准施策。国标《网络安全技术人工智能应用安全分类分级方法》和《网络安全技术人工智能安全能力成熟度评估方法》在全国网安标委正式立项。高风险场景(如控制关键设施、生成法律文书)要求本地化部署、人工兜底与全链路审计;低风险场景(如客服问答、内容摘要)则采用轻量级护栏与自动化监控。这种“精准滴灌”模式既守住安全底线,又避免抑制创新活力。中国人工智能产业联盟发布的《人工智能安全承诺》与大模型安全基准测试 2.0 版推动企业自律、信息共享与能力验证,构建起覆盖标准、评估、响应与追溯的闭环治理体系,在守住安全底线的同时兼顾创新活力。

国际合作层面,2025 年 3 月,中国信通院牵头的大模型基准测试 ITU 国际标准正式发布,规范了大模型基准测试的指标要求和测试方法,旨在推动大模型基准测试体系架构形成国际共识,引导大模型技术及产业健康有序发展。2025 世界人工智能大会期间,中国信息通信研究院牵头发布《中国人工智能安全承诺框架》,进一步凝聚人工智能安全治理国际合作、防范前沿人工智能安全风险等治理共识。

治理实践层面,企业逐步构建覆盖全链条的技术防护体系:开发环节通过数据清洗、安全对齐与红队测试筑牢源头;部署环节依托云网加固、容器安全与权限最小化构建可信运行基座;应用环节则通过访问控制、水印溯源与动态行为评估实现持续监控。2025 年,人工智能安全风险治理体系加速向全生命周期、动态闭环演进。我国通过 CNCERT 三层治理框架与信通院“两横三纵”实践模型,推动技术、管理与制度深度融合,实现从开发、部署到应用的纵向贯通与横向协同。治理重心由事后响应转向前置防控,高风险场景实施本地化部署、人工兜底与全链路审计,低风险场景则采用轻量化监控,形成分级精准施策机制。同时,行业生态协同显著增强。



2025 年标志着“智能体元年”的到来，AI 智能体正成为网络安全能力演进的核心载体。相较于传统安全编排自动化与响应（SOAR）仅实现预设流程的自动化，AI 智能体依托“推理—行动—观察—调整”的闭环能力，推动安全运营从被动响应向主动防御跃迁。其本质特征在于任务自主性：能够理解目标、规划路径、调用工具（如查询日志、调用 EDR、分析流量），并在执行中动态优化策略，扮演“数字安全员工”角色。在实际应用中，智能体已形成标准化工作流：首先对海量告警进行初筛以识别高风险信号；继而融合资产、日志与威胁情报等多源遥测数据，开展深度分诊与影响评估；在此基础上，可在有限人类指导下主动开展威胁狩猎，挖掘潜伏攻击；最终制定并执行响应措施，如隔离终端、阻断 IP 或重置凭证。据谷歌《2026AI 智能体趋势报告》，46% 的已部署企业将智能体用于安全运营，主要应对“告警疲劳”——82% 的分析师担忧因过载而漏判真实威胁。

在 RSA2025 大会上，Microsoft 推出 SecurityCopilotAgents 公开预览版，支持自主执行威胁狩猎、钓鱼分类与身份风险评估；GoogleCloud 发布基于 Gemini 的安全 AI 代理，实现恶意软件分析与自然语言驱动的响应编排；PaloAltoNetworks 则聚焦防御 AI 增强型攻击，推出 LLM-GeneratedAttackDetection 功能，专门识别大模型生成的钓鱼内容与恶意脚本。

Palo Alto Networks 称 2026 年是“防守者之年”，未来发展的方向是采用集成式、原生人工智能的安全平台，这些平台能够整合数据、自动化防御，并最终实现安全、自主的企业愿景。AI 安全平台（AI Security Platforms），统一治理提示注入、数据泄露、恶意代理行为，覆盖端点、网络、云、AI 层，实现联防联控、实时检测与策略下发。Gartner 预测，到 2028 年将有超过 50% 的企业采用 AI 安全平台进行统一治理。

IBM 预测 2026 年将出现“智能体操作系统”，通过策略驱动的统一运行时环境，集中管理智能体的身份、合规、资源与安全基线。这意味着安全能力将从单体智能体内生防护，转向体系化、平台化的治理架构。

在国内范围的智能体赋能网络安全实践与落地，深信服持续投入，2024 至 2025 年间推出了面向网络安全垂直场景的“安全 GPT”系列垂域智能体（具体包括安全运营智能体、威胁检测智能体、数据安全智能体、钓鱼检测智能体等），并于 2025 年正式发布支持用户侧安全垂域智能体构建的 AI 安全平台，真正实现了从“AI 为辅”向“AI 为主”的安全范式迁移。深信服的安全垂域智能体是基于深信服安全大模型，在特定任务上进行微调与知识注入，具备领域专业性与高准确率。2025 年，融入了安全 GPT 和 AI 安全平台的深信服网络安全产品和解决方案已在金融、政务、医疗等行业部署，标志着国内厂商在“专用智能体 + 平台化开发”路径上的实质性进展。

“自动升级至人类”机制成为智能体确保安全边界的重要手段，用于在政务、金融等高敏感场景中对关键决策和高风险操作进行人工接管与复核，从而降低误判、越权及系统性风险。为确保安全边界，当前智能体普遍采用“自动升级至人类”机制：当遭遇超出权限范围、涉及核心资产、存在合规风险或模型置信度不足的情形时，系统将事件连同完整证据链、推理过程与处置建议移交人工专家。这一“人在环路”原则在政务、金融等高敏场景中尤为关键，既提升效率，又避免越权决策。





大模型系统自身安全趋势分析

大模型系统防护对象分析

2025 年，大模型系统架构持续演进，呈现模块化、分布式与多智能体协同特征，安全防护范围已从单一模型扩展至覆盖“算力—数据—模型—应用—身份”五维技术栈，形成纵深防御的基础单元：

系统防护对象层级	核心逻辑与资产范围	对应OWASP LLM风险
1. 设施与供应链层【算力】	涵盖异构算力平台、容器编排、开源框架及第三方组件。	LLM03：供应链风险
2. 数据与知识层【数据】	覆盖训练语料、交互上下文、向量数据库及私有知识库。	LLM02：敏感信息泄露
		LLM04：数据 / 模型投毒
3. 模型与运行层【模型】	涉及模型权重完整性、系统提示词保密性、推理逻辑鲁棒性。	LLM01：提示注入
		LLM07：系统提示泄露
		LLM09：信息误导 / 幻觉
4. 应用与交互层【应用】	包括 API 接口、智能体执行逻辑、前端交互及 MCP 工具链。	LLM05：不当输出处理
		LLM06：过度授权
		LLM10：资源消耗
5. 身份与策略层【身份】	决定系统访问控制的粒度，属于贯穿全层的横切维度。	LLM08：向量与嵌入漏洞
		以及多 Agent 身份风险

表 4-2 大模型防护对象五层

上述五层构成纵向传导链条，任一环节失守均可能通过级联效应引发系统性失效。因此，安全范式正从“以模型为中心”转向“以系统为中心”，强调端到端的完整性、可控性与可审计性。

AI 系统防护策略变化分析

2025 年，AI 系统防护策略受三重驱动影响发生转变：一是提示注入、工具滥用等攻击自动化程度提升；二是多智能体协同场景下权限边界模糊化；三是监管政策对 AI 系统可追溯性与人类干预权提出明确要求。AI 系统防护策略从静态边界防御向“外围动态防御 + 系统内生安全”融合架构的演进，构建“检测—阻断—约束—追溯—干预”五位一体闭环体系。

在此背景下，主流防护策略呈现以下特征：



动态边界防护

在输入 / 输出通道部署轻量级、上下文感知的安全护栏，此类护栏通常基于规则引擎与小模型协同判断，兼顾低延迟与高精度，实时检测并阻断 LLM01（提示注入）、LLM07（系统提示泄露）及 LLM02（敏感信息泄露）。



运行时行为监控

对智能体发起的工具调用、文件操作、网络请求等高危行为实施实时审计与沙箱隔离，结合行为基线异常检测，有效遏制 LLM06（过度授权）引发的横向移动或数据外泄。



原生安全架构

将安全能力深度嵌入系统设计阶段，例如将知识库访问权限与用户身份绑定（应对 LLM08）、为智能体预设最小权限集、在客户端强制启用独立沙箱环境，实现“安全左移”。



全链路可追溯机制

通过日志全量采集、操作链路记录、模型版本与输入输出绑定，构建不可篡改的审计轨迹，满足监管对“过程可回溯、责任可认定”的要求。



身份与策略动态治理

建立 AI 智能体全生命周期管理机制，包括注册、授权、行为监控与权限回收闭环。结合上下文感知（如任务类型、数据敏感度、用户角色），实施动态访问控制，对高风险操作（如删除数据库、调用支付接口）强制引入人类审批节点。

上述策略共同构成“检测—阻断—约束—追溯—干预”五位一体的防护体系，标志着 AI 安全从被动响应走向全生命周期安全防护。

AI 自身安全防护产业情况分析

2025 年，“SecurityforAI”已从理念共识加速迈向工程化落地，产业生态呈现“能力分层、流程嵌入、机制闭环”三大特征：

防护能力分层解耦

基础设施厂商聚焦算力平台可信启动与容器安全；模型平台提供内容过滤、越狱检测与输出合规校验；应用层则强化智能体行为管控与工具调用审计。各层通过标准接口（如 OpenSSFAI 安全 API）实现能力协同。

安全能力工程化落地

企业将风险检测、行为审计、权限控制等能力以标准化组件形式集成至 AI 开发运维（MLOps/LLMOps）全流程。典型实践包括：在 CI/CD 流水线中嵌入模型完整性校验与训练数据扫描；在智能体发布前强制进行工具调用权限审批；在客户端运行时自动启用沙箱与输出脱敏。



高风险领域机制闭环

在高风险领域（如政务、金融、医疗），安全要求进一步聚焦于“输入输出可控、行为可审计、权限可约束、兜底可干预”四大核心原则，推动防护体系从技术堆砌转向机制闭环。

国际方面，2025 年 RSA 大会首次设立“SecurityforAI”专题展区，多家头部安全厂商发布面向大模型系统的专用防护平台。例如，PaloAltoNetworks 推出 MLGuardian，支持实时提示注入检测与智能体行为图谱分析；CrowdStrike 发布 FalconAIShield，集成模型运行时内存保护与供应链完整性验证。值得注意的是，部分厂商提出“SecurityforSecurity”理念，即利用 AI 增强传统安全产品（如 SIEM、EDR）对 AI 系统日志的理解能力，形成双向赋能。

国内产业同步加速布局“SecurityforAI”赛道。深信服发布 AI 驱动的大模型安全护栏，以“AI 保护 AI”的策略，创新性引入快速分类模型和深度研判模型，针对大模型输入输出提供高精度、低时延的检测、阻断能力，帮助用户及时发现和识别大模型的风险，防止大模型应用过程中的有害内容生成、提示词注入攻击、敏感数据泄露等。此外，多家网络安全企业与 AI 平台联合推出符合《生成式人工智能服务安全基本要求》的合规套件，涵盖训练数据脱敏、推理输出过滤、智能体权限管理等模块。

总之，2025 年大模型系统自身安全态势呈现出“风险全域化、防护体系化、能力产品化”的鲜明特征。安全重心已从模型单点防护转向覆盖全技术栈的系统性免疫机制，身份治理与动态策略成为贯穿各层的关键纽带。随着 AGI 临近与多智能体系统普及，系统自身安全将不仅是技术问题，更是制度设计与工程实践的交汇点，为后续跨系统协同安全、物理执行风险防控等议题奠定基础。



攻防场景小结

2025 年人工智能安全态势在风险治理、安全赋能与系统防护三个维度同步演进，呈现出体系化、智能化与纵深化的鲜明特征。

在 AI 安全风险治理方面，风险认知已从碎片化漏洞识别转向覆盖“技术内生—技术应用—应用衍生”的三层体系架构，治理机制加速向全生命周期动态闭环演进。我国通过 CNCERT 治理框架与信通院“两横三纵”实践模型，推动分级分类、前置防控与生态协同，高风险场景实施本地化部署与人工兜底，低风险场景采用轻量监控，实现安全与创新的平衡。

在 AI 赋能网络安全方面，智能体成为安全运营新范式核心，从辅助工具升级为具备自主推理、规划与执行能力的“数字安全员工”。其通过多源数据融合、自动化响应与人在环路机制，显著缓解告警疲劳并提升主动防御能力。然而，随着智能体跨系统执行任务常态化，非人类身份（NHI）治理缺失带来的权限滥用与责任模糊问题日益凸显，亟需构建覆盖注册、认证、授权与审计的全周期身份治理体系。

在大模型系统自身安全方面，防护对象已从单一模型扩展至“算力—数据—模型—应用—身份”多维技术栈，安全策略由边界防御转向“外围动态防护 + 内生安全”融合架构，初步形成“检测—阻断—约束—追溯—干预”五位一体的防护体系。随着 AGI 临近与多智能体协同普及，系统安全正从技术实现迈向制度与工程协同的新阶段。2025 年 AI 安全已进入系统性治理与深度防御并重的新阶段，三大维度相互交织、互为支撑，共同构筑面向未来智能社会的安全基座。

PART FIVE

2026年重点关注趋势



趋势一：身份验证系统、API 接口成为了当前漏洞利用的重点目标，在 AI 技术的驱动下，安全漏洞的利用日益走向自动化与半自动化。

Akamai 发布亚太区 2026 年云与安全展望指出，随着数字银行、公共服务和零售应用日益依赖 API 生态系统，API 生态系统将逐步取代网页应用到大量政企单位，API 漏洞利用将会逐步增多，传统网页漏洞利用将会有所下降。2025 年-2024 年连续 2 年典型攻防场景中，身份系统漏洞利用是横向移动阶段最主要的攻击方式，主要针对常规集控、知识密集型应用和安全设备进行身份攻击。Akamai 发布亚太区 2026 年云与安全展望指出，攻击者利用 AI 进行自动化漏洞扫描、攻击流程编排和攻击负载生成，实现漏洞利用的自动化。

趋势二：传播广泛恶意软件除了开展技术功能演进外，正朝着高欺骗性的伪装、高回报的变现模式以及产业化的方向进行演进。

2025 年“银狐”恶意软件广泛传播，深信服千里目安全技术中心对其研究发现特点包括如下：技术持续“超进化”，免杀版本更新快，年内累计发现近 1 万种新免杀样本，广泛使用“白加黑”、无文件攻击、驱动对抗等高阶技术逃避查杀；攻击过程将形成专业化的产业攻击链，实现分工协作与工具化；恶意载体更注重高欺骗性的伪装策略，深度利用社会工程学手段诱骗目标；同时，其变现模式将趋向高效率、高回报的多元化盈利途径，推动黑色产业链持续扩张。2025 年，“银狐”恶意软件的“流行”并非偶然，其背后是一套从技术对抗到黑色产业化的完整生态。

趋势三：AI 正推动网络安全攻防进入一个自动化、智能化的“军备竞赛”新阶段。

AI 正在改变网络攻防的格局，推动攻防双方的自动化程度不断提高。近日 Fortinet 发布了 2026 年网络安全预测指出，网络安全犯罪正进入自动化时代，黑客组织通过自动化与人工智能大幅度降低攻击成本，与此同时，防守方也在积极通过 AI 技术加速威胁防护与响应。同时，Fortinet 指出由于自动化工具与 AI 技术的导入，预计在 2026 年，攻击周期将从 5 天缩短至 24 小时，还预测了 2027 年在 AI 技术的加持下，可能出现“防御者优势”的转折点。AI 的加入使攻防变成一场“速度竞赛”。攻击窗口的急剧压缩，意味着防御方的检测和响应时间也必须从“天”级缩短到“小时”甚至“分钟”级，响应速度将成为决定成败的关键。

趋势四：大模型的安全防护体系将重点聚焦于内容安全与应用安全两大核心领域

八部门联合印发《“人工智能 + 制造”专项行动实施意见》，指出将推动 3—5 个通用大模型在制造业深度应用，推出 1000 个高水平工业智能体。当前 AI 大模型的广泛应用，进入了支撑实体经济、驱动企业核心业务的关键阶段，因此大模型的安全将被更加重视。2025 年攻防演练暴露，企业在“AI 大模型安全”与“传统 IT 安全”之间存在断层，针对大模型的对抗性攻击防御、内部威胁管控与数据流转监控普遍失效，导致其实际防护能力与企业整体成熟的安全基线严重脱节。2025 年的实战攻防演练揭示，当前安全威胁已高度聚焦于新型攻击面包括大模型自身框架漏洞、凭证泄露风险、云原生环境缺陷，以及提示词注入、代码混淆、深度伪造与多模态攻击等高级对抗技术。为此，我们明确将 2026 年大模型安全体系建设的核心，从泛化的基础防护，转变为“内容安全”与“应用安全”两大支柱，以构建纵深防御能力。

趋势五：AI 智能体身份治理与多智能体通信安全成为核心防线

随着 AI 智能体从单任务助手演进为可自主协作的“超级代理”，其数量将远超人类用户，成为新型数字身份主体。IBM 预测，2026 年 MCP（多智能体通信协议）和 A2A（智能体间通信）等开放协议将推动多智能体系统进入生产环境，但同时也催生跨代理指令投毒、恶意工具注册、身份伪造等新型攻击面。因此，必须将智能体纳入统一的非人类身份（NHI）治理体系，实现身份可声明、权限可约束、行为可审计。安全机制需从单体监控升级为对通信链路策略一致性的全局验证，确保智能体协作既高效又可信。





参考链接

[1]CNNVD (中国国家信息安全漏洞共享平台):

<https://www.cnnvd.org.cn/>

[2]NVD (National Vulnerability Database, 美国国家漏洞数据库):

<https://nvd.nist.gov/>

[3]KEV (Known Exploited Vulnerabilities Catalog, CISA已知被利用漏洞目录):

<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

[4]2025 年漏洞统计: CVE、零日漏洞和利用数量创历史新高

<https://deepstrike.io/blog/vulnerability-statistics-2025>

[5]SOCRadar: 2025 年十大勒索软件组织

<https://socradar.io/blog/top-10-ransomware-groups-2025/>

[6]CrowdStrike 2026 年全球威胁报告:

<https://www.crowdstrike.com/en-us/global-threat-report/>

[7]谷歌2026年威胁预测报告 Cybersecurity Forecast 2026

<https://cloud.google.com/security/resources/cybersecurity-forecast>

[8]OWASP LLM (OWASP大型语言模型/生成式AI Top 10风险):

<https://owasp.org/www-project-top-10-for-large-language-model-applications/>

[9]CNCERT发布《人工智能安全治理框架(2.0版)》:

https://www.cac.gov.cn/2025-09/15/c_1759653448369123.htm

[10]中国信息安全测评中心《人工智能安全风险测评白皮书》(2025年版)：

官方渠道或下载可参考：<https://www.gm7.org/archives/27555>（附下载链接）或其他转载平台（如 Sohu、Vzooko 等）。白皮书由中国信息安全测评中心牵头编制。

[11]谷歌《2026 AI智能体趋势报告》(Google Cloud AI Agent Trends 2026)：

<https://cloud.google.com/resources/content/ai-agent-trends-2026>

[12]Microsoft推出Security Copilot Agents公开预览版(支持威胁狩猎、钓鱼分类、身份风险评估等)：

<https://learn.microsoft.com/en-us/copilot/security/agents-overview>

[13]Google Cloud发布基于Gemini的安全AI代理(恶意软件分析、自然语言驱动响应等)：

<https://cloud.google.com/security/ai> (Gemini in Security Operations / Threat Intelligence)

[14]Palo Alto Networks称2026年是“防守者之年”：

<https://www.paloaltonetworks.com/perspectives/2026-the-year-of-the-defender/>

[15]IBM预测2026年将出现“智能体操作系统”(Agentic Operating System / AOS)：

<https://www.ibm.com/think/news/ai-tech-trends-predictions-2026>

[16]RSAC 2025/2026 AI安全主题总结：

<https://futurumgroup.com/insights/rsac-2026-the-ai-tragedy-of-the-commons-and-the-future-of-agentic-security/>

[17]Akamai《2026 年亚太地区云与安全预测》

<https://www.c114.com.cn/news/16/a1301628.html>

Inside the Industrialization of Cybercrime: What to Expect in 2026

<https://www.fortinet.com/blog/industry-trends/inside-industrialization-of-cybercrime-what-to-expect-in-2026>

[18]工业和信息化部等八部门关于印发《“人工智能+制造”专项行动实施意见》的通知

https://www.nda.gov.cn/sjj/zwgk/zcfb/0112/20260107214358696030895_pc.html

The trends that will shape AI and tech in 2026

<https://www.ibm.com/think/news/ai-tech-trends-predictions-2026>





让每个用户的数智化更简单、更安全



深信服官方微信



深信服移动官网

深圳市南山区西丽街道西丽社区仙洞路16号深信服科技大厦

售前咨询：400-806-6868 售后服务：400-630-6430

邮编：518055 邮箱：market@sangfor.com.cn

